Data Privacy Impact Assessment (DPIA) Register + Person Graph DPIA

> **DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization; not yet adopted.** · 2026-07-05

> **Revised 2026-10-22** — register re-checked against `origin/main` (`aceb080a0a`): R-01 updated (explicit opt-in, 18+ gate, selfie erased 12 h after the event); R-03 re-scoped (government ID, liveness and AML screening retired 2026-07-03); R-05 corrected (parents' entries about their children ARE processed today); R-06 retired (Contract Intelligence retired 2026-05-18); new rows R-09 → R-12 screened (supplier capture lane, AI receipt reading, site Visits, Pabuya gift records). Processor list corrected.

> Prepared under RA 10173 (Data Privacy Act of 2012), its IRR, and NPC guidance on Privacy Impact Assessments (NPC Advisory No. 2017-03 and related issuances). This register indexes every Setnayan processing system that warrants a DPIA and records its assessment status; Part 2 is the first fully-worked DPIA (the adults-only Person Graph).

0. Instrument identity

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II · DTI Business Name Reg. No. 8297508. Operating brand: Setnayan.
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · dpo@setnayan.com · registered on the NPC DPO system 2026-07-07
Register owner	DPO (Indalecio Sacdalan Casasola II)
Key infrastructure / processors	Vercel (hosting) · Supabase (Postgres, Singapore region) · Cloudflare R2 (object storage, Asia-Pacific (APAC)) + relay + bot check · Resend (transactional email) · Sentry (errors) · Anthropic (receipt reading, Deep Search, screening) · OpenAI (moderation) · LanguageTool (grammar) · Google / Apple (sign-in, connections). (!) Corrected 2026-10-22: Persona / Veriff / Onfido and AMLC / ComplyAdvantage struck (retired 2026-07-03); full list in Privacy Manual § 8.2
Governing policy	`01_Contracts/Setnayan_Privacy_and_Security_Policy.md` (v1, locked 2026-05-12; Person-Graph amendment 2026-07-05 in DRAFT)
Register status	DRAFT — pending DPO adoption
Register version / date	2026-07-05 · **revised 2026-10-22**

Part 1 — DPIA Register (index)

Each row is a distinct processing system (or coherent processing activity) assessed for whether it warrants a DPIA, and, if so, the DPIA's current status.

Status legend: Complete = full DPIA finished and DPO-signed · **In-progress** = DPIA drafting/assessment underway · **Pending — counsel-first** = DPIA required before or alongside build; must be reviewed by PH counsel + DPO before the processing goes live (or, where noted, before it is designed).

Risk-level legend: HIGH / MED / LOW = inherent risk to data-subject rights and freedoms before residual-control weighting (biometric, government-ID, financial, minors, and involuntary-inference processing default to HIGH).

#	Processing system	Data-subject(s)	Sensitive-data trigger	Risk level	DPIA status	DPIA owner	Last reviewed
R-01	**Face vectors / biometric auto-tagging** — 128-dim per-event face vectors from RSVP photo + portal upload + check-in kiosk, used to auto-tag gallery photos	Guests	**Biometric = sensitive personal information (RA 10173 § 3(l))**	**HIGH**	**In-progress — counsel-first** — full DPIA now DRAFTED: see **`06_DPIA_Face_Vectors_DRAFT_2026-07-05.md`**. Headline finding: current "implicit consent" via RSVP photo upload is likely insufficient for biometric data — explicit, separate, evidenced face-recognition opt-in required before wider rollout. Pending DPO/counsel sign-off.	DPO	`[TO CONFIRM date]`

R-01a	**Face vectors — status update 2026-10-22**	Guests	Biometric	HIGH → residual Low–Med	[OK] **The consent finding is resolved in code:** a separate, default-off face-recognition tick, an 18+ confirmation, refusal of a guest the host marks as a minor, consent time/source/copy-version stamped; the selfie and vector are erased 12 hours after the event (3-month backstop); withdrawal blurs and keeps the photo. **Still open:** DPO/counsel sign-off of `06_DPIA_Face_Vectors` (revised 2026-10-22) and the owner's 2026-09-30 call that face tagging is ON by default for events with Papic (in code the event default is `papic_face_mode = mode_b`, where live auto-tagging does not run, and christening / debut events are forced to `mode_b`).	DPO	2026-10-22

R-02	**Person Graph** (connections + life-story references + trusted-circle signal), adults-only	Adult account holders + claimed/seeded persons	Relationship data; potential sensitive inference	MED (residual Low)	**Complete** — see Part 2 of this document	DPO	2026-07-05 (this draft)
R-03	**Vendor verification** — business documents (DTI, BIR 2303 with TIN, Mayor's Permit, bank proof), portfolio, client references, 15-minute Google Meet identity call	Vendors (primary representatives)	TIN on BIR 2303 (government identifier); legacy pre-2026-07-03 ID uploads until swept	**MED** (was HIGH)	**Pending** — DPIA still to be written (task `t2-9`). (!) **Re-scoped 2026-10-22:** the government ID, liveness/selfie and AMLC sanctions/PEP screening were **retired 2026-07-03**; no Persona / Veriff / Onfido / ComplyAdvantage relationship exists, so no cross-border transfer to them. Raw uploads deleted 90 days after the decision (sweep built, PR #4735). Automated document checking was proposed and **not started** (owner 2026-09-16).	DPO	2026-10-22

R-04	**Payments & reconciliation** — apply-then-pay orders, BDO/GCash reference matching, partial bank/e-wallet details on receipts, payment-inbox reconciliation	Customers, vendors	Financial data (partial account identifiers; transaction history)	**MED**	**Pending** — DPIA to be written; note no full card/CVV/account numbers stored (§ 1.1 of policy).	DPO	`[TO CONFIRM date]`
R-05	**Minors & Legacy (Phase 3 — stewarded / branch accounts)** — guardian-held child memories to age of majority; post-mortem legacy transfer down the family line	Minors; deceased persons' data; guardians/heirs	Data about minors; post-mortem control; guardianship consent	**HIGH**	**Pending — counsel-first · NOT PROCESSED YET** — adults-only today; **no minor data is processed.** A full DPIA + NPC consultation is required **before any design-to-build**, not merely before launch. **FLAGGED.** Instrument: `Phase3_Minors_and_Legacy_Counsel_Brief_2026-0`	DPO	`[TO CONFIRM date]`

R-05a	**Minors — correction 2026-10-22**	Children (entered by parents)	Data about minors; religion	**HIGH**	(!) **"No minor data is processed" is not accurate for today's product.** Stewarded accounts and legacy transfer are still unbuilt, but parents **do** enter their children's details for christenings and milestones (`dependents`: name, birth date, sex, religion, each consent-stamped; never shown publicly), and guest lists can include children. `/privacy` §"Minors, dependents, and religious information" discloses it. Face enrolment is refused for a known minor. A DPIA covering the live dependents feature is owed (task `t2-9`; control `dependent_minor_profiles`).	DPO	2026-10-22

R-06	~~**Contract Intelligence (0032)**~~	—	—	—	[X] **RETIRED 2026-05-18** (replaced by built-in dual e-signature; SKU `contract_intelligence_per_contract` inactive). No contract text goes to any AI. Row kept for lineage (corrected 2026-10-22).	DPO	2026-10-22
R-07	**Chat / communications (0019)** — customer↔vendor messages, thread file attachments (docs/images/PDF), pasted external meeting links	Customers, vendors, coordinators, guests	Free-text messages may contain incidental sensitive data	LOW–MED	**Pending `[TO CONFIRM]`** — video meetings retired 2026-05-16 (no video data stored); text + files persist to Postgres/R2. Owner to confirm standalone vs. folded.	DPO	`[TO CONFIRM date]`

R-08	**Anti-Fraud & Trust Integrity** — identity clustering (shared device/address/payment), per-cluster de-dup of vendor trust stats, vendor fraud scoring, + two-stage enforcement (reversible auto-suspend + four-eyes wipe/ban)	Couples/guests (identity-clustered) + vendors (scored/enforced)	**Involuntary profiling + automated decision with significant effects** (auto-suspend / ban); repurposed device/address/payment personal data	**HIGH**	**In-progress — counsel-first · LIVE AHEAD OF SIGN-OFF** — full DPIA now DRAFTED: see **`08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.m`** Shipped to prod 2026-07-07 (PRs #2834/#2835/#2836/#2838/#2841) ahead of counsel review (owner-elected). Headline finding: processing is **undisclosed** — a Privacy Policy Anti-Fraud amendment (notice + § 12(f) basis + right to object) + a documented LIA + a formal automated-decision contest path are required. Pending DPO/counsel sign-off.	DPO	`[TO CONFIRM date]`

R-09	**Supplier Papic capture lane + supplier copies + guest takedown** (ROPA DPS-24)	Guests and couples in supplier photos	Likeness captured by a third party (the supplier) and kept as the supplier's own copy / portfolio	**MED**	**Screened 2026-10-22 — DPIA recommended** before the guest-side takedown entry point is built; the migration header still reads "COUNSEL-GATED". Takedown reaches all four capture tables in code; guests cannot yet file one against a supplier-held photo.	DPO	2026-10-22
R-10	**AI reading of payment-proof screenshots** (ROPA DPS-08)	Customers (payers)	Financial information (account name, partial number) sent to Anthropic (US)	**MED**	**Screened 2026-10-22 — no full DPIA needed** if kept as built: the AI never decides a payment, the transcript is not stored, disclosed on `/privacy`. Needs a signed DPA with Anthropic (task `t2-8`).	DPO	2026-10-22

R-11	**First-party site Visits** (ROPA DPS-21)	All site visitors	IP + user-agent hashed for one day only	**LOW**	**Screened 2026-10-22 — no DPIA needed:** no cookie, no stored IP, salt and hashes destroyed daily, aggregates hold no personal data. Disclosure on `/privacy` + `/cookies` still owed.	DPO	2026-10-22
R-12	**Pabuya gift records** (ROPA DPS-28)	Couples, gift-giving guests	Self-disclosed financial details + payment screenshots	**LOW–MED**	**Screened 2026-10-22 — no DPIA needed;** disclosure on `/privacy` still owed (task `t1-5`).	DPO	2026-10-22

Notes on the register.
- Rows R-06 and R-07 are listed for completeness and are candidates for consolidation into adjacent DPIAs at the DPO's discretion; they are **not** the priority items.
- The four priority items for counsel are **R-01 (biometric)**, **R-03 (vendor ID)**, **R-05 (minors/legacy)**, and — for confirmation of two narrow bases only — **R-02 (person graph)**. **R-08 (anti-fraud) is now a fifth priority — and uniquely urgent because it is already LIVE in production ahead of counsel review** (see `08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md` status banner); its transparency/disclosure gap should be closed promptly.
- `[TO CONFIRM date]` in every "Last reviewed" cell must be set by the DPO on adoption; R-02's review date is the date this draft is signed off.

Part 2 — Full DPIA: Person Graph (adults-only)

> Formalizes and expands the self-assessment in `03_Strategy/Compliance_Pack_PersonGraph_DRAFT_2026-07-05.md` § 2 into the NPC PIA/DPIA structure. Scope is strictly the **adults-only** Phase-2 person-graph features live behind flags as of 2026-07-05. **Minors and legacy (Phase 3) are expressly out of scope** and carry their own counsel-first DPIA (register R-05).

2.1 Description of the processing

What is processed.
- **Person node** — a durable profile: name, optional photo, and the list of events the person takes part in. Every

account is one person; a person may also be *seeded* by a host (e.g. added as a guest) and later *claimed* by the real person so their own history follows them.
- **Connections** — a relationship edge between two people. Type ∈ {spouse, parent, sibling, child, godparent, friend}; state ∈ {pending → confirmed}. Extended/derived relationships (grandparents, cousins, in-laws) are **computed on read, never stored**.
- **Life-story items** — **references (pointers), not copies**, to a photo/clip/editorial the person appears in, so the item can also surface in that person's own private archive. No image bytes are duplicated; media stays in its single system-of-record (R2).
- **Trusted-circle signal** — a **computed, aggregated** count of how many people in a person's circle explicitly endorsed a given vendor. **Not stored** as a per-person record.

Why (purpose). To let a person's memories and confirmed relationships follow them across events (the product's core "living memories" purpose), and to surface aggregate, consent-based vendor trust signals — without building a browsable social directory or any advertising/data-broker use.

Data subjects. Adult Setnayan account holders and adult persons seeded by a host and not-yet-claimed. No minors.

Data categories.
- Identity: name, optional photo (already collected under policy § 1.1/§ 1.3).
- Relationship: first-degree declared edges only; extended kin derived, not stored.
- Content references: pointers to media the person appears in (governed by the source media's own consent + retention).
- Derived/aggregate: trusted-circle count (computed, not stored).
- **Not collected here:** contact details of connected persons (name-only visibility), face/biometric origin (no face field in the graph schema), booking history as a trust input.

Systems / data flows.
1. Person A initiates a connection request → B receives a just-in-time notice → B confirms or declines.
2. Edge becomes real **only on mutual confirmation**; declined edges are suppressed immediately.
3. Life-story references are assembled from events where photo-sharing consent was given at RSVP; the person can hide any item or opt out of an event's story without touching the host's gallery.
4. Trusted-circle score is computed at read time from **explicit endorsements/reviews only**, gated by min-N ≥ 5, degree ≤ 2, never from bookings, never purchasable.
5. Storage: `person_connections` (edges) + `person_story_items` (references) in Supabase Postgres (Singapore); referenced media in Cloudflare R2 (Asia-Pacific, APAC). Deny-by-default RLS; participant-scoped access only.

2.2 Necessity & proportionality assessment

- **Lawful basis.** Consent (RA 10173 § 12(a)) via mutual confirmation for connections; existing event photo-consent (RSVP) for life-story references; legitimate interest / aggregate-only for the trusted-circle signal, gated so no individual is identifiable. `[TO CONFIRM]` — DPO/counsel to confirm the precise § 12/§ 13 basis mapping per data category.
- **Necessity.** Each element is necessary for the stated purpose: connections require the counterpart's identity to be meaningful; life-story references require a pointer to the source media; the trusted-circle signal requires endorsement counts. No element collects more than the purpose needs.
- **Proportionality / minimization applied.**
- Only **declared first-degree edges** are persisted; extended kin is derived, not stored.
- Cross-person visibility is **name-only** — no contact details cross the edge.
- Life-story items are **references, not copies** — no media duplication.
- Trusted-circle is **computed, not stored**, and **aggregated (min-N ≥ 5)**.
- The graph is **not browsable** — no "people you may know", no directory, no broadcast.

- **Conclusion.** The processing is necessary and proportionate to the purpose, with data minimization enforced structurally (schema + RLS), not merely by policy.

2.3 Consultation

- **DPO:** this DPIA is prepared for DPO review and sign-off (Indalecio Sacdalan Casasola II). Two narrow items (cross-event archiving basis; long-lived memory retention basis) are referred to the DPO/counsel for confirmation — see § 2.5.
- **Data subjects:** consulted at the point of processing via just-in-time consent/notice strings (drafted in the Compliance Pack § 1) rather than a formal survey; mutual-confirmation design means no processing occurs without the counterpart's active choice.
- **External counsel / NPC:** not required for the adults-only graph beyond the two confirmation items; **required** before any Phase-3 (minors/legacy) work (register R-05).

2.4 Risk assessment table

Inherent risk = likelihood × impact **before** controls. Residual risk = risk remaining **after** the controls already built.

#	Risk	Likelihood	Impact	Inherent	Controls already built	Residual
PG-1	Exposing a person's data to someone they did not consent to	High	High	**High**	Mutual confirmation required; **name-only, confirmed-only** cross-person visibility (SQL `visible_connection_names`); no contact details cross the edge; deny-by-default RLS	**Low**
PG-2	The graph becoming a browsable social directory	Med	High	**High**	Participant-scoped RLS; no "people you may know"; no browse/search; edges private to the two people only	**Low**

PG-3	A person's photo appearing in another's archive without a basis	Med	High	**Med–High**	Built on event-level photo consent (RSVP); per-person **hide** + per-event **opt-out**; **references not copies**; host gallery untouched	**Low–Med** — cross-event archiving basis to be confirmed with counsel (see § 2.5)
PG-4	Inferring sensitive information from relationship data	Med	Med	**Med**	Extended kin **derived, not stored**; **min-N** ≥ **5** on any aggregate; only declared first-degree edges persisted	**Low**
PG-5	Vendor recommendations exposing who-used-whom	Med	High	**Med–High**	Aggregate-only; **min-N** ≥ **5**; explicit-endorsement-only (**never bookings**); degree ≤ 2; not purchasable	**Low**
PG-6	Cross-event face recognition / biometric creep	High	High	**High**	**Structurally impossible in this schema** — association is tag/QR/confirmed-identity only; no face origin field; face vectors stay **per-event** (policy § 1.4)	**Low**
PG-7	Pending requests leaking a name before consent	Med	Med	**Med**	Names resolve **only for confirmed edges**; pending requests show a neutral label	**Low**

PG-8	Data kept longer than justified (over-retention)	Med	Med	**Med**	Follows event/account retention (policy § 4); hide/opt-out takes effect immediately; a reference dies with its source media	**Low–Med** — long-lived "memory" retention basis to be confirmed with counsel (see § 2.5)

2.5 Residual-risk conclusion

Residual risk across the person graph is **Low overall.** The design applies data minimization and consent structurally — mutual confirmation, name-only + confirmed-only visibility, min-N ≥ 5 aggregation, references-not-copies, per-person hide / per-event opt-out, no cross-event face recognition, and deny-by-default RLS — so the two highest inherent risks (PG-1, PG-6) reduce to Low.

Two items are flagged for counsel confirmation (not redesign):
1. **PG-3 — cross-event photo archiving basis.** Confirm that the event-level RSVP photo consent is an adequate lawful basis for a photo the person appears in to also surface in *their own* private archive across events. (Counsel brief §4.4 reference.)
2. **PG-8 — long-lived "memory" retention basis.** Confirm the lawful basis and disclosure for intentionally long-lived preservation of memories (the product's purpose), so retention is justified-and-disclosed rather than open-ended.

Recommendation. Proceed with the adults-only person graph **once (a) the Privacy Policy Person-Graph amendment (2026-07-05) is approved and (b) the two confirmation items above are answered** by the DPO/counsel. No redesign is indicated.

2.6 Sign-off

Role	Name	Signature	Date
Data Protection Officer	Indalecio Sacdalan Casasola II	___	`[TO CONFIRM date]`
Personal Information Controller	Indalecio Sacdalan Casasola II (for SETNAYAN SOFTWARE DEVELOPMENT SERVICE)	___	`[TO CONFIRM date]`

Next review date: `[TO CONFIRM date]` (recommend: at any material change to the person-graph schema/consent, or 12 months from adoption, whichever is sooner).

This is a compliant baseline prepared ahead of counsel; it is not a substitute for legal review. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel. The Person-Graph Privacy Policy amendment publishes only after sign-off; the biometric (R-01), vendor-verification (R-03), and minors/legacy (R-05) DPIAs remain outstanding and counsel-first.